



QR Payment Platform

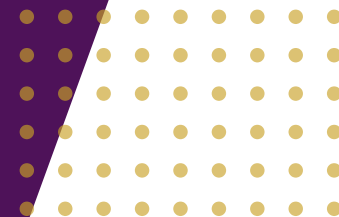
Infrastructure Design Review

TechStart · a group under EastWest ITG

HA · Scalability · Observability · BSP readiness

TECHSTART

Your dream · Our focus



What we built

1 The product

- Customer scans a QR at checkout
- Pays from their bank account
- Merchant order releases on payment

2 The build

- 2 Python / Flask services
- One database each
- Integrated over REST

3 Where it runs

- AWS EC2 — dev / test
- Azure ACI — production
- Jenkins build and deploy

4 What we need

- Review of HA and scaling
- Observability direction
- BSP readiness check

Verified end to end

31.00

order total
settled

1,469.00

payer balance
after debit

300 s

QR validity
window

2 s

merchant status
poll interval

2

services, 2
databases

Figures observed from both services executed end to end, not estimated.

Business requirements and assumptions

Requirements — as built

#	Requirement	Status
1	Customer pays a merchant by scanning a QR code	Working
2	QR expires automatically after 5 minutes	Working
3	A QR cannot be paid twice	Working
4	Merchant sees payment without refreshing	Working
5	Order releases only after funds actually move	Gap
6	Platform survives losing one instance	Gap

The one functional gap

The merchant order is marked paid before the money moves. Two databases commit one after the other, so a failure between them leaves an order paid with no matching debit.

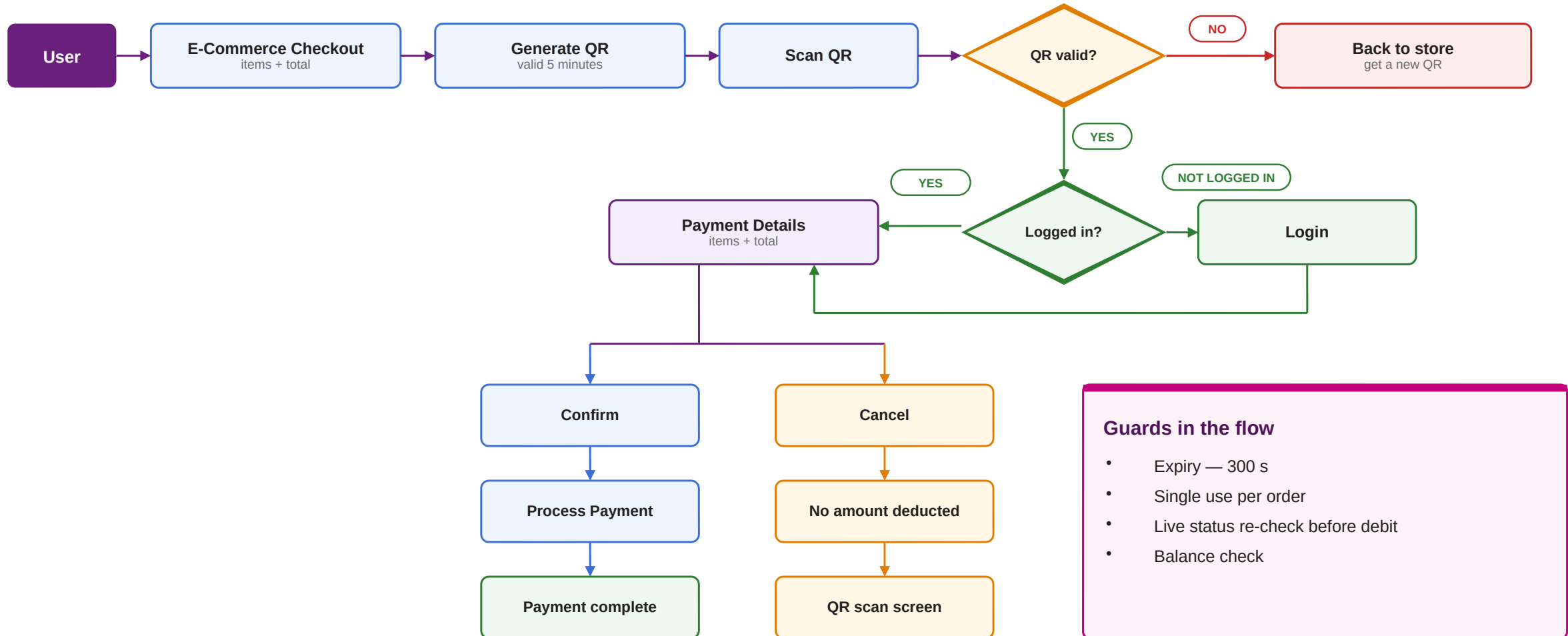
Assumptions

- Azure and AWS accounts are lab, not production
- Prototype volume — no throughput target agreed
- Services stay separately deployable
- Existing Kubernetes manifests are the intended runtime

If an assumption is wrong

- Lab → production changes urgency, not the plan
- A volume target changes all sizing here
- A shared ITG cluster changes the Kubernetes plan

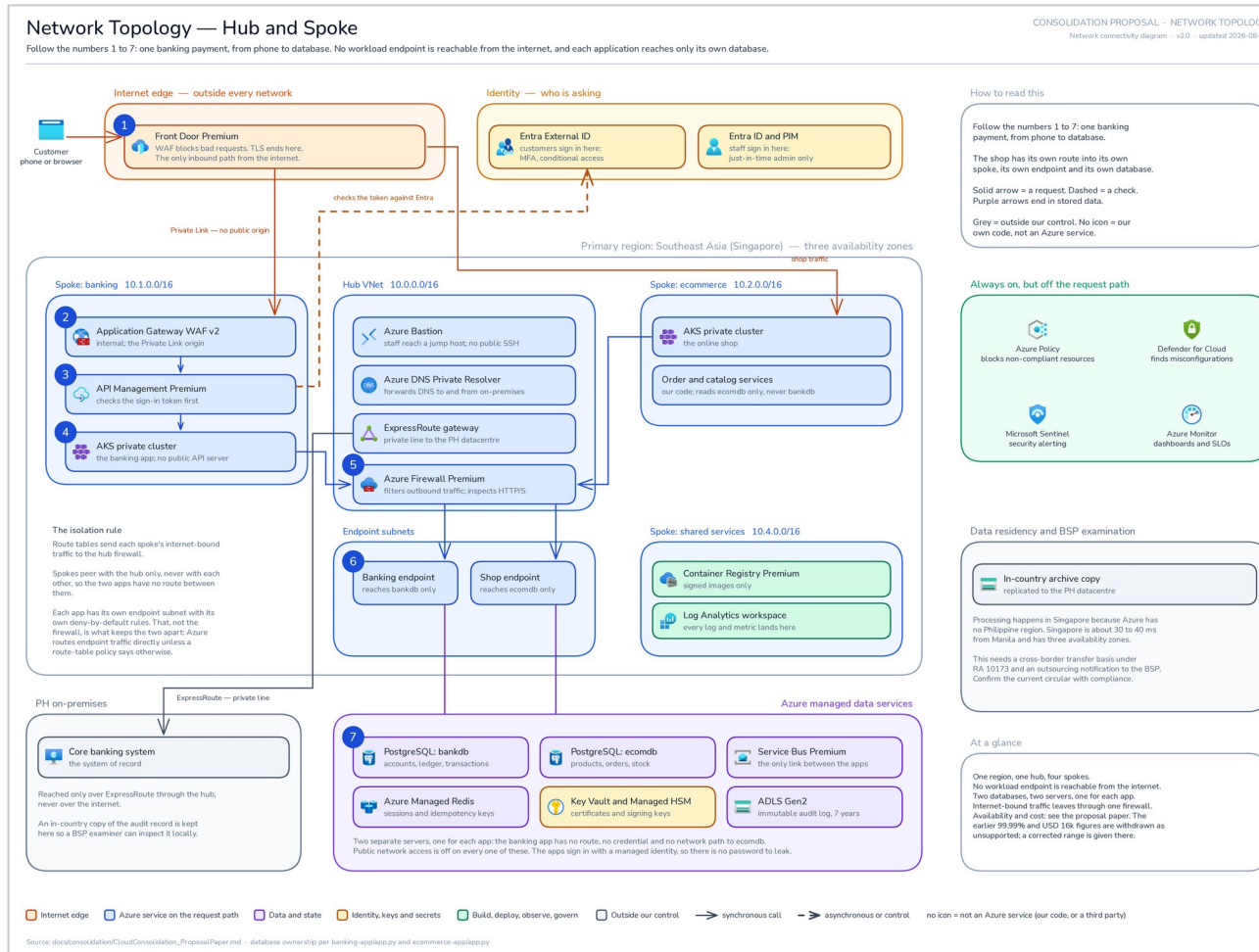
User flow



Flow reviewed against the code: QR validity is 300 seconds (5 minutes).

Target architecture — hub and spoke

One region, one hub, four spokes. No workload endpoint reachable from the internet.



One banking payment, phone to database

- 1 Front Door Premium** TLS ends here; WAF; the only way in
- 2 Application Gateway WAF v2** internal — the Private Link origin
- 3 API Management Premium** checks the sign-in token first
- 4 AKS private cluster** the banking app; no public API server
- 5 Azure Firewall Premium** inspects everything outbound
- 6 Banking endpoint** reaches bankdb only
- 7 PostgreSQL — bankdb** accounts, ledger, transactions

Why this shape

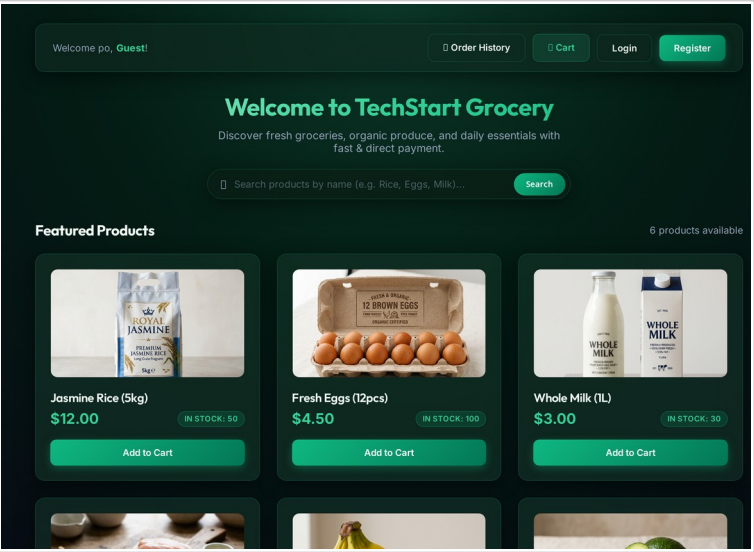
- Spokes peer with the hub only — apps cannot reach each other
- Service Bus is the only link between the apps
- Core banking over ExpressRoute, never the internet

Open with the infra team

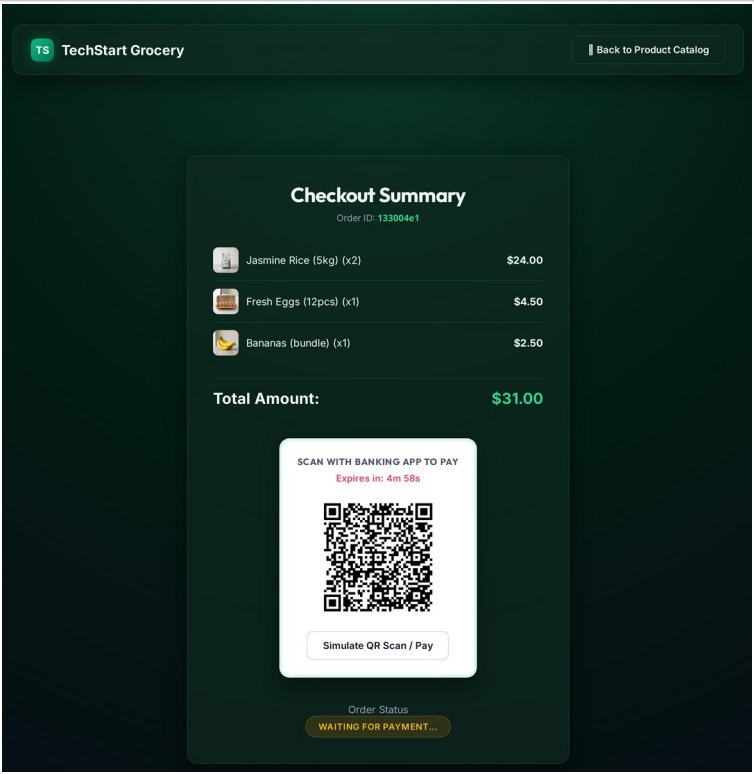
- Singapore region — cross-border basis and BSP notice required

The application, running

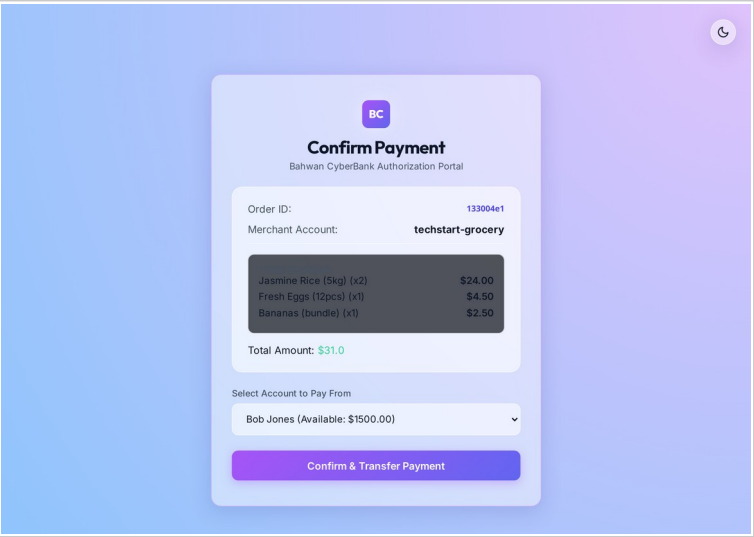
Merchant catalogue



QR presented at checkout

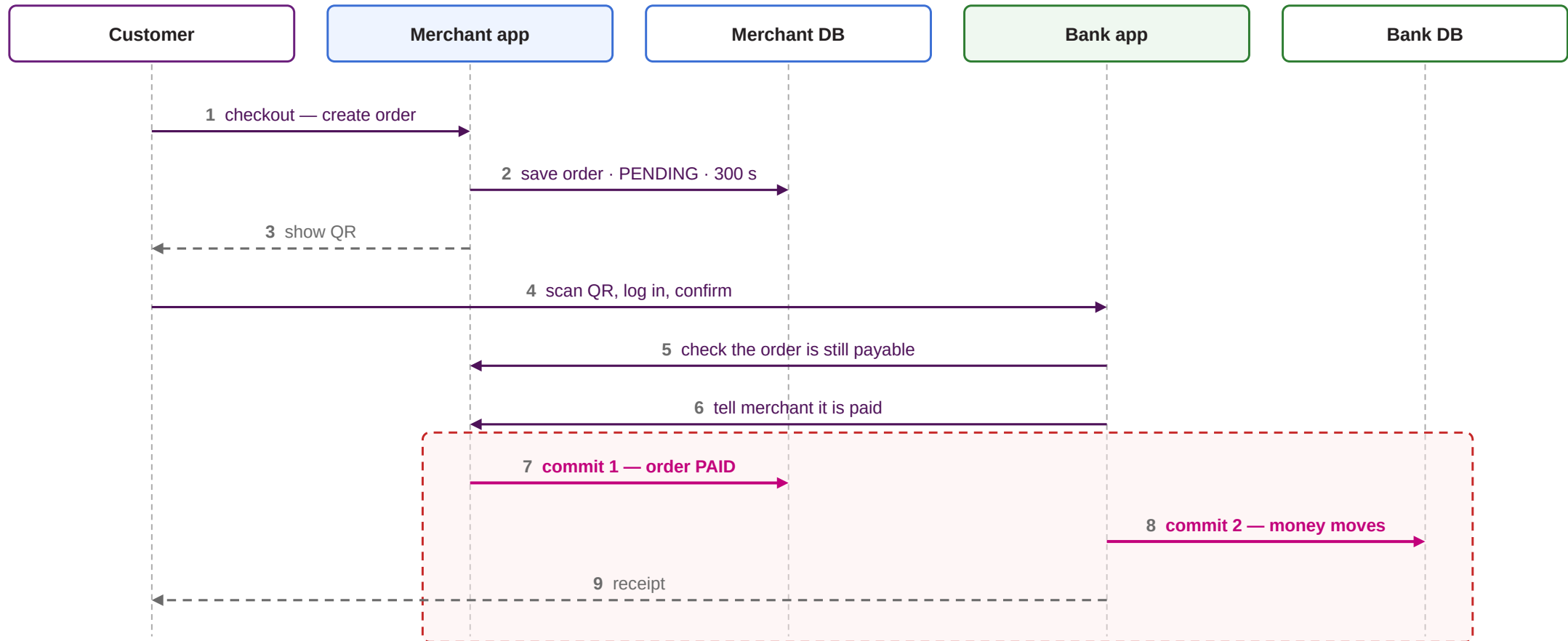


Authorising in the bank app



Live captures from both services running end to end. Images are placed at their true aspect ratio.

How a payment moves



Steps 7 and 8

Two commits, two databases, nothing joining them. This is the gap.

High availability

Layer	Today	What we think it should be
Edge	One Nginx container, no failover	Managed gateway, health-probed backend pool
Application	2 containers, but no load balancer in front	2+ replicas actually load balanced
Database	Single node, no replica	Zone-redundant managed instance
Backup	None configured, no restore ever tested	Automated backup, PITR, rehearsed restore
Deploys	Delete then recreate — outage every release	Rolling update, gated on readiness

0

tiers with a redundant
instance taking traffic

100%

of releases cause
a planned outage

?

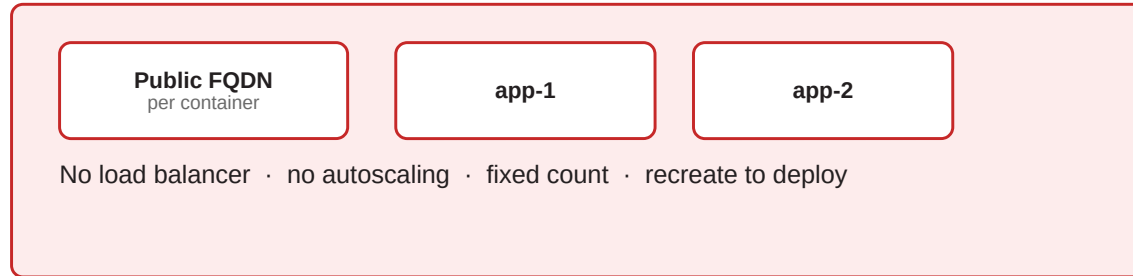
RPO and RTO
never agreed

Ask the infra team

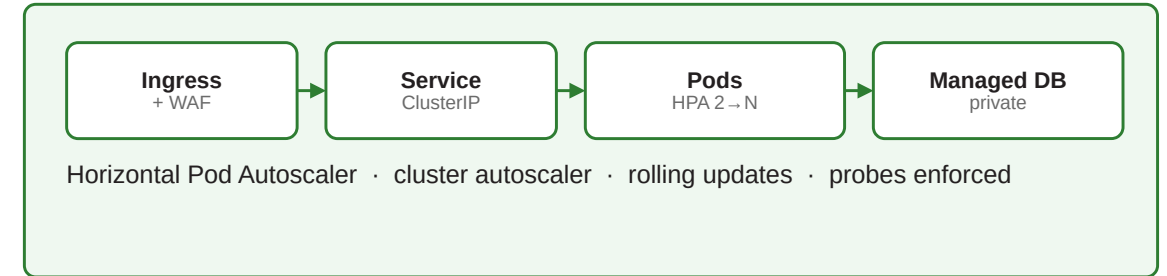
- What availability target applies here?
- What RPO and RTO do we design to?
- Standard gateway pattern in ITG?

Scalability on Kubernetes

Today — Azure Container Instances



Proposed — AKS



Already done

- Deployment, Service and Secret manifests written
- Liveness and readiness probes defined
- Config is all environment variables
- Stateless request handling

Blockers to fix first

- Session key is per-instance — externalise it
- Service type is LoadBalancer — should be ClusterIP
- Secrets are plaintext in the manifest
- No connection pooling for the database

Ask the infra team

- AKS or Container Apps for this workload?
- Is there a shared ITG cluster we join?
- What scales it — CPU, or requests per second?
- Who owns the manifests after handover?

Observability

Logs

NOW

print() to stdout, lost on redeploy

TARGET

Container Insights → Log Analytics, structured JSON

Metrics

NOW

None collected

TARGET

Azure Monitor, workload dashboards

Traces

NOW

No correlation ID between services

TARGET

OpenTelemetry → App Insights

What this costs us today

- A failed payment is discovered by the customer, not by us
- An incident cannot be reconstructed after the fact
- /health exists — but nothing is configured to call it
- No dashboard, no alert, no on-call signal

Ask the infra team

- Standard ITG logging stack for us to use?
- Azure Monitor or Dynatrace?
- Who receives the alerts?

BSP readiness

Instrument	Requirement	Where we stand
Circular 1055	QR Ph — EMVCo standard, signed payload	Not met — our QR is a plain URL
Circular 1198	Merchant onboarding, settlement, disputes	Not met — no KYC or settlement
MORB App. 75	Encryption in transit and at rest, key management	Not met — HTTP throughout
Circular 1140	Technology outsourcing, exit plan, BCP	Partial — no exit or BCP yet
RA 10173 (DPA)	Lawful basis for cross-border data transfer	Open — data sits in centralindia
RA 9160 (AMLA)	Covered and suspicious transaction reporting	Not met — no reporting

The two that need a decision, not code

- Cross-border data — Azure has no PH region, so a transfer basis is required
- Licensing under Circular 1198 may apply before any launch

Ask the infra team

- Who owns the QR Ph conformance work?
- Is there an existing ITG cross-border transfer basis we inherit?
- Which controls does ITG already provide centrally?

Engineering-side mapping only, not a legal opinion. Every citation to be confirmed with Compliance and Legal.

Feedback and recommendations

To be filled in with the Infrastructure team during this session

Feedback

Recommendations

Action items · owner
